SECURITY

NationFiles // Security Governance (ISO-aligned)

STAND 27.02.2026 · EN

NationFiles

Neawolf Media Group

Neawolf Media Group
Reinhardstr. 1b
52078 Aachen, Germany

Security

As of: 27.02.2026

PDF from: 18.04.2026 21:30

> **This document describes NationFiles' security governance model along the CIA triad (Confidentiality, Integrity, Availability). Target audiences: authorities, B2B partners and security-conscious users. Technical internals are not disclosed for security reasons.**

SECURITY TL;DR

Defence in depth: 6 strategic pillars – data integrity, IPS, audits, zero-knowledge, API resilience, governance

User: TLS 1.3, HSTS (365 days), nonce-based CSP, strict anonymisation without PII storage

TIER 3 – THE WATCHMAN: Weekly automated audits (SCA/SAST) every Sunday 02:00 UTC; externally validated real-time monitoring (60s interval) for SLA compliance.

TIER 4 – GLOBAL DATA PRIVACY: Zero-knowledge, no PII in core; nonce-based CSP, frame-ancestors, anonymisation and data minimisation.

1. INFRASTRUCTURE HARDENING & PERIMETER PROTECTION (THE SHIELD)

IPS Naciro-Shield

Real-time analysis of behaviour patterns; immediate system-wide 7-day ban on SQLi attempts, brute-force and anomalies. Automated governance without manual intervention.

WAF at network edge

Malicious user agents, SQL injection patterns and XSS payloads are blocked at the edge before they reach application logic.

TLS 1.3 & HSTS

Enforcement of TLS 1.3; HSTS with preload duration of 31,536,000 seconds (1 year). Prevention of man-in-the-middle attacks.

Disaster Recovery

Daily server snapshots for RTO < 4h; encrypted, geographically separated Git vaults for source code and configuration (technological sovereignty).

2. APPLICATION INTEGRITY & CODE GOVERNANCE (THE CORE)

100 % PDO prepared statements

All database transactions parameterised; SQL injection architecturally excluded. Immutable data logic.

URI whitelist & path-traversal protection

Strict regex validation of all URI segments; path traversal and directory listing prevented at source.

Isolated secrets management

API keys and credentials only in encrypted layers outside web root, physically separated from the dispatcher.

Naciro AI integrity

Specialised hardening against prompt injection and data poisoning; manipulation of calculations and forecasts by external actors excluded.

3. CONTINUOUS AUDIT CYCLES (THE WATCHMAN)

Weekly audit (Sunday 02:00 UTC)

Full system audit on a fixed schedule; SCA and SAST run automatically.

Real-time monitoring (60s interval)

Externally validated real-time monitoring at 60-second intervals to ensure SLA compliance.

SCA – CVE scan

Full scan of all third-party libraries against global CVE databases (Software Composition Analysis).

SAST – PHPStan & OWASP

Static code analysis via PHPStan (Level 5+); pattern matching against OWASP security standards.

Pentests PT-01 to PT-15

Structured test process with 15 documented scenarios (PT-01 to PT-15); business-logic fuzzing and complex attack simulation.

4. GLOBAL DATA PRIVACY (USER & CUSTOMER)

Zero-knowledge & anonymity

No PII storage in core; full anonymisation of visitor access; data minimisation per ISO.

Nonce-CSP & frame-ancestors

Content Security Policy with nonce; only verified code in the browser. frame-ancestors protection against clickjacking.

API partner isolation

Strict isolation, signature and origin validation; rate limiting and IPS protection against brute-force and replay.

TIER 1: INFRASTRUCTURE RESILIENCE (THE SHIELD)

Intrusion Prevention System (IPS): The proprietary Naciro-Shield based on Fail2ban analyses behaviour patterns in real time and imposes an immediate system-wide 7-day ban on anomalies (SQLi attempts, brute-force). Web Application Firewall (WAF): An upstream network-layer defence blocks malicious user agents, SQL injection patterns and cross-site scripting payloads at the edge before they reach application logic. Transport security: Enforcement of TLS 1.3 and HSTS with a preload duration of 31,536,000 seconds (1 year) to prevent man-in-the-middle attacks. Business continuity: Daily server snapshots (RTO < 4h) and encrypted, geographically separated Git vaults secure technological sovereignty and recoverability.

TIER 2: ARCHITECTURAL INTEGRITY (THE CORE)

Immutable data logic: 100% coverage of all database transactions by parameterised queries (PDO prepared statements). The architecture physically excludes SQL injection vectors. Input sanitisation: Strict whitelist validation of all URI segments via restrictive regex filters to prevent path traversal and directory listing attacks at source. Isolated secrets management: All API keys and system credentials reside in encrypted layers outside the web root, physically separated from the public dispatcher. The Naciro engine is specifically hardened against prompt injection and data poisoning – external actors cannot manipulate calculations and forecasts. Naciro AI governance: bias monitoring, protection against data poisoning, and full audit trails for algorithmic decision processes (AI Act ready).

TIER 3: CONTINUOUS COMPLIANCE (THE WATCHMAN)

Weekly automated audits (SCA/SAST) every Sunday at 02:00 UTC. SCA (Software Composition Analysis): Full scan of all third-party libraries against global CVE databases (vulnerability tracking). SAST (Static Application Security Testing): In-depth analysis of code logic via PHPStan (Level 5+) and pattern matching against OWASP security standards. Externally validated real-time monitoring (60s interval) secures SLA compliance. Manual pentests: Regular structured penetration tests (PT-01 to PT-15) to simulate complex attack scenarios and business-logic fuzzing. Results are evaluated and documented internally. Supply chain integrity: maintenance of an internal SBOM (Software Bill of Materials) and continuous SCA validation of all third-party components to secure technological sovereignty.

TIER 4: GLOBAL DATA PRIVACY (USER & CUSTOMER)

Zero-knowledge architecture: No PII storage in the core system; full anonymisation of visitor access and data minimisation per ISO principles. Client security: Nonce-based Content Security Policy (CSP) and frame-ancestors protection against clickjacking. TLS 1.3 and TLS 1.2 and HSTS (365 days) enforce encrypted communication. For API partners: strict isolation, signature and origin validation, rate limiting and IPS protection against brute-force and replay attacks.

https://nationfiles.com/en/legal/security/

As of: 27.02.2026

Only the German version is legally binding.

This page does not replace legal advice and does not constitute official warnings or recommendations. Forecasts and assessments are model-based.

Contact for legal inquiries: see imprint.

Abuse/DMCA: abuse@nationfiles.com

Transparency & data ethics: nationfiles.com/legal/governance/

Sources & licences: nationfiles.com/legal/sources/

Infrastructure: Processing exclusively in Germany, TLS 1.3, VPC isolation.

Data protection: Processing of personal data in accordance with GDPR; no sharing or use for AI training.

Liability: No liability for external content or derived decisions. No investment advice within the meaning of the German Securities Trading Act (WpHG).

Place of jurisdiction: Aachen, Germany. German law applies to the exclusion of the UN Convention on Contracts for the International Sale of Goods (CISG).

© NationFiles / Neawolf Media Group – All rights reserved.